TLP:CLEAR Unrestricted public release.

CYBER THREAT INTELLIGENCE REPORT

APT29-linked watering-hole campaign uses n-day exploit chains on iOS and Android

From **Cybersecurity Briefing 2026-11-04** · 2026-11-03 to 2026-11-04 (last 24 hours; Indianapolis and Indiana sections cover 2026-10-30 to 2026-11-04) · Briefing generated 2026-11-04

REPORT ID	VERSION	HANDLING
CTI-20261104-03	1.0 · 2026-11-04 10:11 EST	TLP:CLEAR
BRIEFING SECTION	**ORIGINAL PUBLISHED**	**LAST UPDATE**
Global	2026-11-04	No update
CVES	**ANALYST**	
CVE-2025-43529 (CVSS 8.8), CVE-2024-27834 (CVSS 5.5), CVE-2026-20700 (CVSS 7.8), CVE-2025-14174 (CVSS 8.8), CVE-2025-43510 (CVSS 7.8), CVE-2025-43520 (CVSS 5.5), CVE-2026-3910 (CVSS 8.8), CVE-2025-27038 (CVSS 7.5)	Nick Sturgeon	

NATION-STATE | HIGH | ACTIVELY EXPLOITED | OVERALL CONFIDENCE: MODERATE

BOTTOM LINE UP FRONT

Sekoia's Threat Detection & Research team reported on 4 November 2026 a watering-hole campaign against iPhone and Android users, and assessed with moderate-to-high confidence that APT29 (Midnight Blizzard, tied to Russia's SVR) ran it [S2] [S4]. Three delivery routes led to the same fingerprinting script: JavaScript injected into legitimate sites, reverse-proxy lookalike domains, and a one-week compromise of the Ukrainian Plerdy analytics tracker from 27 August to 3 September 2026 [S2] [S4]. Named or described victims include a Ukrainian gas producer, a U.S. chemical industry trade association, a Bulgarian military-related site and a Czech far-right movement's site, while the lookalikes imitated the America250 site and Raffles London at The OWO [S1] [S2] [S4] [S5].

The delivery server chose one of three exploit chains based on the device. Class A hits iOS 16.7 and steals cookies. Class B hits iOS 18.5, is built on the DarkSword kit, and harvests messages, WhatsApp and Telegram databases, Keychain data, Wi-Fi passwords, location caches, photos and iCloud Drive files. Class C hits Chrome 139-145 on Android (excluding 143) and uses a payload Sekoia calls AndroSnitch to take Chrome cookies, saved logins, history and Wi-Fi configuration [S2] [S3] [S5]. No user action is needed

beyond loading the page, which is why coverage calls this zero-click; NVD scores the browser-side flaws as requiring user interaction, so a visit to the page is the trigger [S1] [S19] [S25]. No payload persists, so a reboot ends the activity until the device reaches a compromised site again, but anything already stolen, including live session cookies, stays useful to the attacker [S1] [S4].

Every flaw was patched before the campaign began, so the exposure is devices that are behind on updates [S2]. Seven of the eight CVEs show CISA KEV entries in NVD, with all due dates long past [S19] [S21] [S22] [S23] [S24] [S25] [S26]. Two caveats apply to the simple 'just patch' message. iPhones limited to iOS 16 (iPhone 8, 8 Plus and X) received iOS 16.7.15 and 16.7.16 with no listed fix for the Class A CVEs, and Apple's notes for those releases do not mention them [S12] [S13]. The Qualcomm Adreno fix for Android arrived through the 2025-08-05 Android patch level, which depends on the device maker shipping it [S15].

Not yet known: how many devices were compromised, how the attacker got into the victim websites, whether stolen cookies were used against corporate accounts, and how much of the targeting was deliberate. Sekoia itself is unsure whether the goal was specific visitors or wide collection [S3]. Defenders should bring mobile fleets to current releases (iOS 27.2, 26.7.2 or 18.7.11, and current Chrome) [S10], retire devices stuck on iOS 16, use Lockdown Mode for high-risk staff who cannot update [S5] [S6], search DNS and proxy logs for the listed indicators, check any Plerdy use, and revoke sessions for anyone with a likely hit.

Key judgments

VERY LIKELY · HIGH CONFIDENCE
Over the next 6 to 12 months, state and criminal actors will very likely keep using packaged iOS and Android n-day kits through compromised websites, because DarkSword and Coruna are widely available and already spread by several groups. [S2] [S3] [S6] [S9]

LIKELY · MODERATE CONFIDENCE
The operators will likely move to new delivery and exfiltration infrastructure within weeks of Sekoia's publication, so the published domains and IPs are more useful for looking back at past traffic than for future blocking. [S2] [S5]

LIKELY · MODERATE CONFIDENCE
Additional compromised sites or lookalike domains from this campaign, including some with a U.S. connection, will likely be identified as CERTs and vendors act on Sekoia's data, since Sekoia holds further indicators and is working with national CERTs. [S2] [S4]

LIKELY · LOW CONFIDENCE
Cookies stolen in this campaign were likely used to reach webmail or other accounts without passwords. This rests on the design of the payloads and the actor's earlier cookie theft, as no source has confirmed account takeover in this campaign. [S4] [S5] [S7]

> UNLIKELY · LOW CONFIDENCE
> A typical Indiana small or mid-size business is unlikely to be a deliberate target of this operation, though staff could be caught incidentally if they visit an affected site on an outdated phone, particularly staff in chemical manufacturing, defense supply or government roles. [S2] [S3] [S4]

INDICATORS OF COMPROMISE

Reported indicators come mainly from Sekoia's 4 November 2026 report; Sekoia holds additional indicators and YARA rules for national CERTs and law enforcement under TLP:AMBER, so this list is partial. Some are historical (the Plerdy window closed on 3 September 2026, and one lookalike was already offline), and entries labeled related or historical come from other clusters and are not tied to this campaign.

Type	Indicator (defanged)	Context	Provenance	First seen	Source
domain	`theowo[.]club`	Reverse-proxy lookalike of Raffles London at The OWO; served script from static.flux-telemetry.com. Sekoia lists it as offline. Date is domain creation.	REPORTED	2026-06-18	[S2] [S5]
domain	`america250[.]holiday`	Reverse-proxy lookalike of an America250 site; linked to delivery domain adsprism-stat.com. Date is domain creation.	REPORTED	2026-05-19	[S2] [S3] [S5]
domain	`static[.]flux-telemetry[.]com`	Delivery host for the fingerprint script and exploit server. Date is domain creation.	REPORTED	2026-04-02	[S2] [S5]
domain	`edge-ord[.]clouds-stacks[.]com`	Delivery host acting as load balancer and redirector; used in the Plerdy injection. Date is domain creation.	REPORTED	2026-08-26	[S2]
domain	`ad[.]starx-net[.]com`	Exfiltration host for all three chains; also serves Class B stages. Date is domain creation.	REPORTED	2026-04-03	[S2] [S3] [S5]
domain	`adsprism-stat[.]com`	Malicious delivery domain tied to america250.holiday.	REPORTED		[S2] [S5]
domain	`ads-it-assets[.]com`	Redirect target of edge-ord.clouds-stacks.com.	REPORTED		[S2]
domain	`cdn[.]adv-static[.]com`	Redirect target of edge-ord.clouds-stacks.com.	REPORTED		[S2]
domain	`wpvortex-mod[.]com`	Redirect target of edge-ord.clouds-stacks.com.	REPORTED		[S2]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
domain	`assets-int[.]com`	Redirect target of edge-ord.clouds-stacks.com.	REPORTED		[S2]
domain	`a[.]plerdy[.]com`	Legitimate analytics host that was compromised from 27 August to 3 September 2026. Treat hits as suspicious only inside that window; not malicious infrastructure in itself.	REPORTED	2026-08-27	[S2] [S3] [S5]
domain	`flux-telemetry[.]com`	Parent domain of the reported delivery host; the name is also a Sekoia-derived hunting keyword per secondary coverage. Hunt on the parent to catch sibling hosts.	DERIVED		[S2] [S5]
domain	`clouds-stacks[.]com`	Parent domain of the reported redirector host; the name is also a hunting keyword per secondary coverage. Hunt on the parent to catch sibling hosts.	DERIVED		[S2] [S5]
domain	`starx-net[.]com`	Parent domain of the reported exfiltration host; the name is also a hunting keyword per secondary coverage. Hunt on the parent to catch sibling hosts.	DERIVED		[S2] [S5]
ipv4	`109[.]104[.]106[.]107`	Resolved from static.flux-telemetry.com; AS395092 Shock Hosting LLC.	REPORTED		[S2]
ipv4	`95[.]133[.]231[.]28`	Resolved from edge-ord.clouds-stacks.com; AS219399 servinga GmbH.	REPORTED		[S2]
ipv4	`195[.]58[.]140[.]105`	Resolved from ad.starx-net.com; AS395092 Shock Hosting LLC.	REPORTED		[S2]
ipv4	`192[.]121[.]46[.]25`	Resolved from america250.holiday; AS9009, listed by Sekoia as EDIS GmbH.	REPORTED		[S2]
ipv4	`188[.]190[.]17[.]232`	Resolved from theowo.club; AS57169 EDIS GmbH.	REPORTED		[S2]
url	`hxxps[://]static[.]flux-telemetry[.]com/module/5b4c8fea5cbcee273e8d830f52-temfp[.]js`	UltimateFingerprinter script loaded by the injected code on the gas company's site.	REPORTED		[S2]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
url	`hxxps[://]edge-ord[.]clouds-stacks[.]com/module/5b4c8fea5cbcee273e8d830f52-temfp[.]js`	UltimateFingerprinter script loaded via the compromised Plerdy tracker.	REPORTED		[S2]
url	`hxxps[://]a[.]plerdy[.]com/public/js/click/main[.]js`	Plerdy tracker file modified during the compromise window. The file is legitimate outside that window.	REPORTED	2026-08-27	[S2] [S3]
url	`hxxps[://]static[.]flux-telemetry[.]com/api/uGmlx2pmMHU1jq7wZU2QWgeC28vbXalf/v1`	Fingerprint submission endpoint (POST, JSON). The path segment is described as a random nonce, so it may vary.	REPORTED		[S2]
url	`hxxps[://]ad[.]starx-net[.]com/api/<NONCE>/v1`	Class B stage 1: WebContent code execution (CVE-2025-43529) with PAC bypass (CVE-2026-20700).	REPORTED		[S2]
url	`hxxps[://]ad[.]starx-net[.]com/api/<NONCE>/v2`	Class B stage 2: sandbox escape (CVE-2025-14174, then CVE-2025-43510).	REPORTED		[S2]
url	`hxxps[://]ad[.]starx-net[.]com/api/<NONCE>/v3`	Class B stage 3: kernel read/write (CVE-2025-43520) and the post-exploitation harvester.	REPORTED		[S2]
url	`hxxps[://]ad[.]starx-net[.]com:8881/telemetry/v12`	Exfiltration endpoint used by all three chains.	REPORTED		[S2] [S3] [S5]
port	8881	Exfiltration port on ad.starx-net.com. Outbound HTTPS on this port from a phone is unusual, but check for false positives.	REPORTED		[S2] [S3]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
http-request	`POST /api/<nonce>/v1` with a JSON fingerprint body; an accepted response is JavaScript added to document.head	Fingerprint exchange. An empty 200 OK comes back if screen dimensions are implausible or navigator.maxTouchPoints is 0.	REPORTED		[S2]
http-request	`POST /telemetry/v12` with JSON fields `category`, `data`, `deviceUUID`, `path`	Class A exfiltration by fetch() to port 8881.	REPORTED		[S2]
http-request	`HTTP request headers Filename and X-Device-Id`	Sent by the Class C shellcode, which uses libcurl for exfiltration.	REPORTED		[S2]
http-request	`GET /module/*-temfp.js`	Generalized from the two reported fingerprint script URLs to catch the same path on new hosts. Could produce false positives and is only visible with TLS inspection or full URL logging.	DERIVED		[S2]
filename	`5b4c8fea5cbcee273e8d830f52-temfp.js`	UltimateFingerprinter script, appended as dead code to a minified AngularJS library of about 2.3 MB.	REPORTED		[S2] [S5]
filename	`libexploit.so`	AndroSnitch internal name.	REPORTED		[S2]
filepath	`/private/var/mobile/Containers/Data/Application/<UUID>/Library/Cookies/Cookies.binarycookies`	Legitimate iOS cookie store targeted for theft. Not malicious on its own.	REPORTED		[S2]
filepath	`/var/mobile/Cookies/`	Legitimate iOS cookie location targeted for theft. Not malicious on its own.	REPORTED		[S2]
filepath	`/data/data/com.android.chrome/app_chrome/Default/`	Chrome profile directory; AndroSnitch reads Cookies, Login Data and History. Legitimate location.	REPORTED		[S2]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
filepath	`/data/misc/apexdata/com.android.wifi/WifiConfigStore.xml`	Android saved Wi-Fi configuration targeted by AndroSnitch. Legitimate file.	REPORTED		[S2]
filepath	`/data/misc/apns/0/WifiConfigStore.xml`	Second Wi-Fi configuration path targeted by AndroSnitch.	REPORTED		[S2]
filename	`sms.db`	Legitimate iOS message store targeted by Class B. Others named by Sekoia are Envelope Index, Protected Index, Accounts3.sqlite and History.db.	REPORTED		[S2]
filepath	`/private/var/tmp/wifi_passwords.txt`	Sekoia names wifi_passwords.txt in Class B collection. The full path comes from Google's YARA rule for GHOSTBLADE, a related DarkSword payload, so the path in this campaign is unconfirmed.	REPORTED		[S2] [S6]
other	`VDGH_TOKEN_REF`	Marker cookie set by Class A and B as a replay guard. A date error makes it last about one minute instead of a day. Class C does not use it.	REPORTED		[S2]
other	`only_cookies`	JSON category and path value seen in exfiltration data.	REPORTED		[S2]
other	`SM-S938B`	Samsung Galaxy S25 Ultra model identifier. The Android chain stops if this is detected.	REPORTED		[S2] [S3]
other	`UltimateFingerprinter`	Name of the fingerprint script; 394 fields from 61 collectors. Useful as a string search.	REPORTED		[S2] [S5]
sha256	`a7d2493df00565c21587b0cad2a9fe7ca1e5590acf796da6e499be0ffde44cc3`	Class-A-Stage1 (Sekoia IOC list).	REPORTED		[S2]
sha256	`bee3e014e3df87ddce0250b0985b87f6868a427a7b650a74b7ffedb9d57f3088`	Class-A-Stage2 (Sekoia IOC list and Class A table).	REPORTED		[S2]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
sha256	`c170fda024183645c0aa681149304e50506509c3498bb6b9a5f5ced6aa73e5fa`	Class-B-Stage1 (Sekoia IOC list).	REPORTED		[S2]
sha256	`35c0cd19a7334b544c193e392bcd9a8f1d1f43cf6b61be5bf1d9e35537aff2ef`	Class B /v1 stage (Sekoia Class B table; differs from the IOC-list hash for this stage).	REPORTED		[S2]
sha256	`2ffb35e3f9e55286a930fb887e73764a913166648135fe0ca7551736d97d7bfa`	Class-B-Stage2 (Sekoia IOC list).	REPORTED		[S2]
sha256	`621112712ec515e8791129c62feda8fff6654a0116882401609503cacc08054a`	Class B /v2 stage (Sekoia Class B table; differs from the IOC-list hash for this stage).	REPORTED		[S2]
sha256	`69b6cb327a4d5da99399718f6a66f84de69f89425b0a31f2dcee0682f811596f`	Class-B-Stage3 and /v3 stage (Sekoia IOC list and Class B table).	REPORTED		[S2]
sha256	`ae3241d96cc2d99538c7aff60f382cc8dac13859bcbea3ee84992d24d22a8108`	Class C JavaScript for Chrome 139-144 (Sekoia Class C table).	REPORTED		[S2]
sha256	`41e6fd33a30d36dabff9ea408d9766a6583edcc107968f6dc1499f2586381967`	Class C JavaScript for Chrome 145 (Sekoia Class C table).	REPORTED		[S2]
sha256	`29d283ebd08d0cd3b2e6f4a67718d3d6e7a6be01d0613d716bce218dba57a928`	Class-C-Stage1-JS (Sekoia IOC list).	REPORTED		[S2]
sha256	`06c17b31d36838f3d29044784aa047d5c2d9174d3356c1211cf25f9df677445f`	Class-C-Stage2-JS (Sekoia IOC list).	REPORTED		[S2]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
sha256	`183d62d682aea8018491c8559544e8d6a9ab0e1abd05ecbb6c97daa4f438d2b8`	Class-C-Stage2-CVE-2025-27038 shellcode (Sekoia IOC list and Class C table).	REPORTED		[S2]
sha256	`387a7fb768db1350a9788d9704e7a72abe07152734e0ff026af72b417e36268c`	AndroSnitch (Sekoia IOC list and Class C table).	REPORTED		[S2]
sha256	`493f8d0a9f0f89c51f74d5f1b5592871bf974b16035e43d202ea91ff12e5dfd4`	DarkSword kit sample Sekoia references through VirusTotal; not in its IOC list and not specific to this campaign.	REPORTED		[S2]
domain	`static[.]cdncounter[.]net`	Related, not this campaign: UNC6353 DarkSword delivery through Ukrainian watering holes. Google has not tied UNC6353 to APT29 in the sources reviewed.	REPORTED		[S6]
domain	`sqwas[.]shapelie[.]com`	Related, not this campaign: UNC6353 GHOSTBLADE exfiltration server.	REPORTED		[S6]
sha256	`2e5a56beb63f21d9347310412ae6efb29fd3db2d3a3fc0798865a29a3c578d35`	Related, not this campaign: extracted GHOSTBLADE sample (UNC6353).	REPORTED		[S6]
domain	`snapshare[.]chat`	Related, not this campaign: UNC6748 Snapchat-themed DarkSword decoy.	REPORTED	2025-11-01	[S6]
domain	`ad-track[.]live`	Related, not this campaign: served a DarkSword P7 variant through a World Cup-themed ad, per iVerify and Report URI as summarized by The Hacker News.	REPORTED		[S3]
domain	`track-adv[.]com`	Historical: 2023-2024 APT29-linked watering-hole delivery against Mongolian government sites.	REPORTED	2023-11-01	[S7]
domain	`ceo-adviser[.]com`	Historical: February 2024 APT29-linked delivery against a Mongolian government site.	REPORTED	2024-02-01	[S7]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

The attacker plants a script loader on a site the target is likely to visit: by changing a page template or an existing JavaScript library, by proxying a real site through a lookalike domain and patching in the script, or by altering a third-party analytics tracker. After the page loads, the loader pulls UltimateFingerprinter, hidden as dead code behind a large AngularJS library, which posts 394 browser and device fields to the delivery host. If the screen size and touch-point checks look like a real phone, the server returns a chain matched to the device: Class A for iOS 16.7, Class B (DarkSword-based) for iOS 18.5, or Class C (AndroSnitch) for Chrome 139-145 on Android. The chains run through browser code execution, then sandbox escape or kernel access as needed, read cookies and other stored data, send them to ad[.]starx-net[.]com on port 8881, and leave no persistence [S2] [S3] [S5].

Threat actor

APT29 · also tracked as Midnight Blizzard, Cozy Bear, The Dukes

Attribution confidence: Moderate · **Motivation:** Espionage. Targeting centers on Ukraine and on U.S. and European organizations of interest to Russia. · **Suspected origin:** Russia (linked to the SVR foreign intelligence service)

This is Sekoia's assessment, stated as moderate to high confidence, and rests on a compromised site matching a private report of a 2025 APT29 watering hole, resemblance to the 2024 Mongolian government campaign that Google tied to APT29 with moderate confidence, infrastructure patterns, and victimology [S2] [S4] [S5] [S7]. This report rates it Moderate because it comes from a single vendor and some evidence is not public. No government has confirmed it in the sources reviewed. Google separately tracks UNC6353, a suspected Russian espionage cluster using DarkSword on Ukrainian sites; the sources reviewed do not say it is APT29 [S6].

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity
Resource Development	T1583.001 Acquire Infrastructure: Domains	Registered lookalike and delivery domains between April and August 2026. [S2]	Monitor newly registered domains that imitate brands or events your staff use.
Resource Development	T1584.004 Compromise Infrastructure: Server	Compromised legitimate web servers to inject the loader. The entry method is not reported. [S2]	File integrity monitoring on web roots and templates; review CMS admin logins.
Resource Development	T1608.004 Stage Capabilities: Drive-by Target	Prepared compromised and proxied sites to serve the fingerprint script. [S2]	Scan your own sites for unexpected script elements added on window.onload.

Tactic	Technique	Procedure observed	Detection opportunity
Resource Development	T1588.005 Obtain Capabilities: Exploit	Reused packaged exploits including DarkSword; Sekoia notes they may trace to a commercial surveillance vendor. [S2] [S3] [S6]	Track DarkSword and Coruna indicators from vendors.
Reconnaissance	T1592.004 Gather Victim Host Information: Client Configurations	UltimateFingerprinter gathers 394 fields, then the server filters on platform, version and basic plausibility. [S2] [S5]	Proxy logs showing POSTs to /api/<token>/v1 on rare domains just after a page load.
Initial Access	T1189 Drive-by Compromise	Visiting a compromised or lookalike site in a vulnerable mobile browser triggers the chain, with no further action required. [S1] [S2]	DNS and proxy hits on listed delivery domains from mobile device ranges.
Initial Access	T1195.002 Supply Chain Compromise: Compromise Software Supply Chain	Plerdy's main.js tracker was altered for one week, exposing thousands of mostly Ukrainian customer sites. [S2] [S3] [S4]	Inventory third-party scripts; use Subresource Integrity and CSP reporting where practical.
Initial Access	T1566.002 Phishing: Spearphishing Link	Suspected only: Sekoia assesses the lookalikes were aimed at spear-phishing around diplomatic or high-profile events. No lure has been published. [S2] [S5]	Search mail logs for links to the listed lookalike domains.
Execution	T1203 Exploitation for Client Execution	WebKit and V8 flaws (CVE-2025-43529, CVE-2026-3910) give code execution in the browser. [S2] [S19] [S25]	Limited on phones; use patch posture from MDM and mobile threat defense alerts.
Execution	T1059.007 Command and Scripting Interpreter: JavaScript	Fingerprinting, exploit delivery and Class A and B post-exploitation logic are JavaScript. [S2] [S6]	Inspect served JavaScript where TLS inspection is in place; hunt for script names in logs.
Privilege Escalation	T1404 Exploitation for Privilege Escalation	CVE-2025-43510 and CVE-2025-43520 on iOS and CVE-2025-27038 on Adreno Android devices extend access past the browser sandbox. [S2] [S6] [S26]	Mobile threat defense alerts; review device patch levels.

Tactic	Technique	Procedure observed	Detection opportunity
Defense Evasion	T1497 Virtualization/Sandbox Evasion	Server returns nothing for implausible screen sizes or zero touch points; the Android chain stops on model SM-S938B. [S2] [S3]	When testing, expect an empty 200 OK from non-phone browsers, so a clean sandbox result is not proof a site is clean.
Defense Evasion	T1027 Obfuscated Files or Information	Script placed behind about 2.3 MB of dead AngularJS code, which may be meant to hinder automated analysis. [S2] [S5]	Flag unusually large scripts from rare domains.
Credential Access	T1539 Steal Web Session Cookie	All chains take browser cookies; Class A takes Cookies.binarycookies and Class C reads Chrome's Cookies database. [S1] [S2] [S4]	Sign-in anomalies showing one session across different IPs or networks.
Credential Access	T1634.001 Credentials from Password Store: Keychain	Class B takes Keychain passwords and tokens. [S1] [S2] [S4]	No practical network-side signal; treat a likely Class B hit as full credential exposure.
Credential Access	T1555.003 Credentials from Password Stores: Credentials from Web Browsers	AndroSnitch reads Chrome's Login Data. [S1] [S2] [S4]	Watch for logins from new locations using passwords saved on the phone.
Collection	T1409 Stored Application Data	Class B collects WhatsApp and Telegram databases, Mail indexes, Notes, Health and Safari History. [S1] [S2] [S3]	Not visible from the network; depends on triage of the device.
Collection	T1636.004 Protected User Data: SMS Messages	Class B reads sms.db for SMS and iMessage content. [S2] [S4]	Not visible from the network; depends on triage of the device.
Collection	T1430 Location Tracking	Class B harvests cached location data. [S1] [S2]	Not visible from the network; depends on triage of the device.
Collection	T1533 Data from Local System	Chains collect photos, iCloud Drive files, wifi_passwords.txt and WifiConfigStore.xml. [S2] [S3]	Large uploads from mobile devices to rare hosts on port 8881.
Exfiltration	T1041 Exfiltration Over C2 Channel	Data goes to ad[.]starx-net[.]com:8881/telemetry/v12; Class A uses fetch() POST and Class C uses libcurl. [S2] [S3]	TLS SNI or DNS hits on the host; outbound volume on port 8881.

Tactic	Technique	Procedure observed	Detection opportunity
Command and Control	T1571 Non-Standard Port	HTTPS exfiltration uses port 8881. [S2] [S3]	Alert on egress from mobile or guest VLANs to uncommon ports.
Lateral Movement	T1550.004 Use Alternate Authentication Material: Web Session Cookie	Assessed follow-on use, not observed in this campaign: stolen cookies could let the attacker reuse logged-in sessions such as webmail without a password. [S4] [S5]	Compare session IDs against user agent, ASN and country in identity logs.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

DNS and proxy hits on campaign infrastructure `SPLUNK SPL`

```
(index=dns OR index=proxy) (query IN ("*flux-telemetry.com","*clouds-stacks.com","*starx-net.com","*adsprism-stat.com","*ads-it-assets.com","*adv-static.com","*wpvortex-mod.com","*assets-int.com","*america250.holiday","*theowo.club") OR url IN ("*flux-telemetry.com*","*clouds-stacks.com*","*starx-net.com*","*adsprism-stat.com*","*ads-it-assets.com*","*adv-static.com*","*wpvortex-mod.com*","*assets-int.com*","*america250.holiday*","*theowo.club*") OR dest_ip IN ("109.104.106.107","95.133.231.28","195.58.140.105","192.121.46.25","188.190.17.232"))
earliest=-210d | stats earliest(_time) AS first latest(_time) AS last count BY src_ip user query url dest_ip
```

Field names vary by source. Look back to April 2026, when the first delivery domains were created. Hosting IPs may be shared. Phones off the corporate network will not appear.

Fingerprint script and Plerdy tracker requests `SIGMA`

```
title: APT29 Mobile Watering Hole Script Retrieval
status: experimental
logsource:
  category: proxy
detection:
  selection_script:
    c-uri|contains: '-temfp.js'
  selection_tracker:
    cs-host: 'a.plerdy.com'
    c-uri|contains: '/public/js/click/main.js'
  condition: selection_script or selection_tracker
level: medium
```

Needs URL visibility through TLS inspection or an explicit proxy. Plerdy matches matter only between 2026-08-27 and 2026-09-03; filter by date during review.

TLS connection to exfiltration host `SURICATA`

```
alert tls $HOME_NET any -> $EXTERNAL_NET any (msg:"Possible APT29 mobile campaign exfiltration host in SNI"; tls.sni; content:"starx-net.com"; nocase; endswith; classtype:trojan-activity; sid:9200101; rev:1;)
```

Local sid. Add a companion rule for port 8881 if your sensors see guest or mobile traffic.

Session reuse across networks `KQL`

```
SigninLogs
| where TimeGenerated > ago(30d)
| where ResultType == 0 and isnotempty(SessionId)
| summarize IPs=make_set(IPAddress, 20), ASNs=make_set(AutonomousSystemNumber, 20), Countries=make_set(Location, 20), UserAgents=make_set(UserAgent, 20), First=min(TimeGenerated), Last=max(TimeGenerated) by UserPrincipalName, SessionId
| where array_length(ASNs) > 1 and array_length(Countries) > 1
```

Generic check for possible cookie replay, focused first on high-risk users and anyone with an infrastructure hit. Travel and VPNs will cause false positives. Extend retention if available, since the campaign began months ago.

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Apple iOS (Class A chain, delivered to iOS 16.7 and 16.7.10)	Delivery filter covers 16.7 and 16.7.10; Sekoia says the exploit reportedly works from 16.0 to 17.4	CVE-2025-43529: iOS 18.7.3, 26.2. CVE-2024-27834: iOS 16.7.8, 17.5. Apple's 16.7.15 and 16.7.16 notes do not list CVE-2025-43529.	CVE-2025-43529, CVE-2024-27834	8.8, 5.5	0.2565 (97.97th pct); 0.00598 (48.75th pct)	CVE-2025-43529: Yes (added 2025-12-15); CVE-2024-27834: No entry shown in NVD; KEV feed could not be fully read	2026-01-05 for CVE-2025-43529; N/A for CVE-2024-27834

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Apple iOS (Class B chain, DarkSword-based, iOS 18.5)	Campaign used iOS 18.5; DarkSword broadly supports iOS 18.4-18.7	iOS 18.7.2/26.1 (CVE-2025-43510, CVE-2025-43520); iOS 18.7.3/26.2 (CVE-2025-43529, CVE-2025-14174); iOS 26.3 (CVE-2026-20700). Current releases: iOS 27.2, 26.7.2, 18.7.11.	CVE-2025-43529, CVE-2026-20700, CVE-2025-14174, CVE-2025-43510, CVE-2025-43520	8.8, 7.8, 8.8, 7.8, 5.5	0.2565; 0.01679; 0.55334; 0.00355; 0.00425 (scored 2026-11-04)	Yes (added 2025-12-15, 2026-02-12, 2025-12-12, 2026-03-20, 2026-03-20 in CVE order)	2026-01-05, 2026-03-05, 2026-01-02, 2026-04-03, 2026-04-03 in CVE order
Google Chrome for Android (Class C chain)	Chrome 139-145 excluding 143	Chrome 146.0.7680.75 for CVE-2026-3910	CVE-2026-3910	8.8	0.02693 (85.94th pct)	Yes (added 2026-03-13)	2026-03-27
Qualcomm Adreno GPU driver on Android (Class C chain)	Qualcomm chipsets listed in the June 2025 bulletin	Fix to OEMs in May 2025; Android patch level 2025-08-05	CVE-2025-27038	7.5	0.01044 (64.22nd pct)	Yes (added 2025-06-03)	2025-06-24

Immediate (0–24 hours)

- Pull an MDM report of iOS, Android and Chrome versions. Force updates for anything on iOS below current releases, Chrome below 146, or Android below the 2025-08-05 patch level, starting with executives, administrators and traveling staff. `IT OPS` [S2] [S10] [S15] [S25]
- Search DNS, proxy, firewall and mobile security logs back to April 2026 for the listed domains and IPs, and for Plerdy tracker requests from 27 August to 3 September 2026. `SOC` [S2] [S5]
- Block the listed malicious delivery, exfiltration and lookalike domains at DNS and proxy layers. Do not block a.plerdy.com solely for this campaign without checking business use. `SOC` [S2] [S5]
- For any device with an infrastructure hit, reboot and update it, revoke all sessions and tokens, and rotate passwords saved on it, plus Wi-Fi passwords it stored. Keep logs before making changes. `SOC` [S1] [S2] [S4]
- If your organization is a chemical sector member or supplier, confirm whether staff use trade association sites, and if the association contacts you, follow its guidance. `LEADERSHIP` [S1] [S4]

Short term (1–7 days)

- Identify devices limited to iOS 16 (iPhone 8, 8 Plus, X) and replace them or remove them from corporate access, since Apple's recent 16.7 notes do not list the Class A fixes. `IT OPS` [S12] [S13]
- Set conditional access rules that block mail and SaaS access from mobile devices below a minimum OS and patch level, including BYOD. `IT OPS` [S2]
- Review your public websites for unexpected script tags and changes to shared JavaScript libraries, and remove the Plerdy tracker or confirm its current file is clean. `IT OPS` [S2] [S5]
- Brief high-risk staff on the campaign and turn on Lockdown Mode for those who accept its limitations or cannot update immediately. `SOC` [S6] [S7]
- Run the session-reuse hunt for high-risk users and review webmail and SaaS access logs for unfamiliar sessions. `SOC` [S4]

Long term

- Add phones and tablets to vulnerability management with a written patch deadline, and treat KEV-listed mobile flaws like server flaws. `LEADERSHIP` [S19] [S25]
- Reduce the value of stolen cookies with short session lifetimes, device-bound or compliant-device access rules, and continuous access evaluation where supported. `IT OPS` [S4]
- Deploy a mobile threat defense product or managed DNS on mobile devices so that traffic off the corporate network is visible. `LEADERSHIP` [S2]
- Keep an inventory of third-party scripts on your websites and use Content Security Policy and Subresource Integrity to limit the effects of tracker compromise. `IT OPS` [S2] [S3]
- Set a hardware lifecycle policy that retires phones before vendors stop full security updates, and restrict sensitive access from older hardware. `LEADERSHIP` [S12] [S13]

Workarounds & compensating controls

- Use Lockdown Mode on iPhones that cannot be updated right away; Apple says it protects against DarkSword, Google recommends it when updating is not possible, and Google also noted it blocked the 2023 iOS chain. `IT OPS` [S6] [S7] [S8]
- Keep Chrome automatic updates on through managed Google Play, and restrict corporate data to compliant browsers on Android. `IT OPS` [S25]
- Do not store corporate passwords in phone browsers, do not keep admin portal sessions on phones, and use phishing-resistant MFA, which helps with password theft but does not stop replay of stolen sessions. `LEADERSHIP` [S1] [S4] [S17]
- Rebooting ends a running payload because none persists, but does not undo data theft, so use it as a stopgap and not as remediation. `IT OPS` [S1] [S4]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] BleepingComputer: Hackers use n-day exploits in zero-click attacks on iOS, Android devices
Published 2026-11-04 · **B2** Usually reliable, probably true
Briefing source; summarizes Sekoia.

[S2] Sekoia TDR: Poisoned source: APT29 watering holes targets mobile devices with n-day exploits
Published 2026-11-04 · **A2** Completely reliable, probably true
Primary research. Attribution comes from a single vendor and partly from non-public data.

[S3] The Hacker News: APT29-Linked Hackers Hijack Web Analytics Script to Deliver iOS and Android Exploits
Published 2026-11 · **B2** Usually reliable, probably true
Adds context on DarkSword P7, DeadTag and Zimperium's Coruna figures. Exact day not confirmed.

[S4] Help Net Security: Russian hackers target iOS and Android users with n-day exploits
Published 2026-11-04 · **B2** Usually reliable, probably true
Secondary; adds the Australian clinic detail and CERT coordination.

[S5] GBHackers: Russian Hackers Create Fake US and UK Websites to Target Visitors With Mobile Exploits
Published · **C2** Fairly reliable, probably true
Secondary. Publication date not confirmed. Its IOC table agrees with Sekoia.

[S6] Google Threat Intelligence Group: The Proliferation of DarkSword: iOS Exploit Chain Adopted by Multiple Threat Actors
Published 2026-03-18 · **A1** Completely reliable, confirmed by other sources
Primary on DarkSword, per-CVE fixes and Lockdown Mode guidance.

[S7] Google Threat Analysis Group: State-backed attackers and commercial surveillance vendors repeatedly use the same exploits
Published 2024-08-29 · **A2** Completely reliable, probably true
Earlier APT29-linked mobile watering holes, assessed with moderate confidence.

[S8] BleepingComputer: New DarkSword iOS exploit used in infostealer attack on iPhones
Published 2026-03-18 · **B1** Usually reliable, confirmed by other sources
Includes Apple's statement on protection and Lockdown Mode.

[S9] BleepingComputer: Apple expands iOS 18 updates to more iPhones to block DarkSword attacks
Published 2026-04 · **B1** Usually reliable, confirmed by other sources
Reports public posting of the kit on GitHub. Exact day not confirmed.

[S10] Apple: Apple security releases
Published 2026-10-30 · **A1** Completely reliable, confirmed by other sources
Current release list.

[S11] Apple: About the security content of iOS 18.7.7 and iPadOS 18.7.7
Published 2026-03-24 · **A1** Completely reliable, confirmed by other sources
DarkSword note; expanded to more devices on 2026-04-01.

[S12] Apple: About the security content of iOS 16.7.16 and iPadOS 16.7.16
Published 2026-05-11 · **A1** Completely reliable, confirmed by other sources
Does not list the Class A CVEs.

[S13] Apple: About the security content of iOS 16.7.15 and iPadOS 16.7.15
Published 2026-03-11 · **A1** Completely reliable, confirmed by other sources
Does not list the Class A CVEs.

[S14] Apple: About the security content of iOS 18.7.5 and iPadOS 18.7.5
Published 2026-02-11 · **A1** Completely reliable, confirmed by other sources
Does not list CVE-2026-20700.

[S15] Android: Android Security Bulletin, August 2025
Published 2025-08-01 · **A1** Completely reliable, confirmed by other sources
CVE-2025-27038 at patch level 2025-08-05.

[S16] BleepingComputer: Qualcomm fixes three Adreno GPU zero-days exploited in attacks
Published 2025-06-02 · **B1** Usually reliable, confirmed by other sources
Qualcomm's own bulletin page did not render, so this is used for the OEM fix timing.

[S17] BleepingComputer: Hotel Wi-Fi attacks use custom malware to breach Microsoft 365 accounts
Published 2026-08-03 · **B2** Usually reliable, probably true
Related Midnight Blizzard sub-cluster activity reported by Microsoft.

[S18] FIRST: EPSS API results for the eight CVEs
Published 2026-11-04 · **A2** Completely reliable, probably true
Probability model output, not proof of exploitation.

[S19] NVD: CVE-2025-43529
Published 2025-12-17 · **A1** Completely reliable, confirmed by other sources
CVSS and KEV fields.

[S20] NVD: CVE-2024-27834
Published 2024-05-14 · **A1** Completely reliable, confirmed by other sources
CVSS and fix versions; no KEV fields present.

[S21] NVD: CVE-2026-20700
Published 2026-02-11 · **A1** Completely reliable, confirmed by other sources
CVSS and KEV fields.

[S22] NVD: CVE-2025-14174
Published 2025-12-12 · **A1** Completely reliable, confirmed by other sources
CVSS and KEV fields.

[S23] NVD: CVE-2025-43510
Published 2025-12-12 · **A1** Completely reliable, confirmed by other sources
CVSS and KEV fields.

[S24] NVD: CVE-2025-43520
Published 2025-12-12 · **A1** Completely reliable, confirmed by other sources
CVSS and KEV fields.

[S25] NVD: CVE-2026-3910
Published 2026-03-13 · **A1** Completely reliable, confirmed by other sources
CVSS, fixed Chrome version and KEV fields.

[S26] NVD: CVE-2025-27038
Published 2025-06-03 · **A1** Completely reliable, confirmed by other sources
CVSS and KEV fields.

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2023-11-01	Start of the APT29-linked Mongolian government watering holes that Google later reported (month-level date).	[S7]
2025-11-01	DarkSword in use by at least this month (month-level date).	[S6] [S8]

Date	Event	Source
2026-02-11	Apple releases iOS 26.3, fixing CVE-2026-20700.	[S10] [S21]
2026-03-13	CVE-2026-3910 published and added to CISA KEV.	[S25]
2026-03-18	Google, Lookout and iVerify disclose DarkSword.	[S6] [S8]
2026-04-01	Apple makes iOS 18.7.7 available to more devices as DarkSword protection.	[S9] [S11]
2026-04-02	static.flux-telemetry[.]com created; ad.starx-net[.]com follows on 3 April.	[S2]
2026-05-19	america250[.]holiday created.	[S2]
2026-06-18	theowo[.]club created.	[S2]
2026-08-26	edge-ord.clouds-stacks[.]com created one day before the Plerdy compromise.	[S2]
2026-08-27	Plerdy tracker compromise begins; ends 3 September 2026.	[S2] [S4]
2026-10-15	Approximate date: Sekoia uncovers the campaign in mid-October 2026.	[S3] [S4]
2026-11-04	Sekoia publishes its report.	[S2]

Relevance to Indianapolis, Indiana & managed clients

No source names an Indiana victim. The clearest local connection is the U.S. chemical industry trade association: Indiana manufacturers, chemical and materials firms, logistics providers and their suppliers may have staff who visit similar industry sites from phones. State and local government offices, universities and hospitals should check phones used by leaders, researchers and those who travel, particularly anyone with work tied to Ukraine, defense or international delegations, or who engaged with America250 events through a lookalike link. Healthcare organizations should note that an Australian clinic appeared among compromised sites, though Sekoia described it as unrelated to the main targeting, and Class B can take Health data and messages from a personal phone. For small and mid-size businesses, the realistic risk is an old phone or BYOD device holding a logged-in Microsoft 365 or webmail session. Managed IT clients should expect a mobile patch report, conditional access for minimum OS levels, and a look at any Plerdy use. Providers should treat phones used by technicians as high value, because a stolen cookie for an administrative portal could expose several clients.

Intelligence gaps

- Number of infected devices and identity of victims are not public.
- Whether stolen cookies led to account access in any organization, U.S. or otherwise, is not reported.
- How the attacker compromised the legitimate sites and Plerdy is not reported, and no Plerdy statement was found.
- The name of the U.S. chemical trade association and how long it was compromised are not in the sources reviewed.
- Whether U.S. or Indiana devices were actually exploited, as opposed to merely exposed, is unknown.
- It is unclear whether the campaign is still active at compromised sites, or how long each site remained compromised.
- The relationship between APT29 and Google's UNC6353, which also used DarkSword against Ukrainian sites, is not stated.
- Apple's iOS 18.7.5 and 18.7.7 notes do not list CVE-2026-20700, and the CVE data shows only iOS 26.3 as fixed. Apple states DarkSword is blocked in protected releases, but per-CVE backport detail for iOS 18 and iOS 16 is incomplete.
- Why the delivery server skips Chrome 143 and why the Android chain stops on SM-S938B are unexplained; Sekoia says the 143 exclusion is unclear.
- CISA KEV status was read through NVD's KEV fields because the full KEV feed was too large to read in one pass, and the catalog search page gave inconclusive results. CVE-2024-27834 has no KEV fields in NVD.
- Watch for CERT-UA or other government advisories, a Plerdy statement, a Microsoft or Google view on the attribution, and the release of further IOCs.

Other notes

- 'Zero-click' needs care here. The attack requires a page load in a vulnerable browser, and the lookalikes may have been sent by spear-phishing, so it differs from zero-click attacks over messaging apps. Report URI's Scott Helme makes a similar point about simply opening a page [S3]. NVD scores CVE-2025-43529 and CVE-2026-3910 as requiring user interaction [S19] [S25].
- Sekoia's report has both stage tables and a final IOC list with different hashes for some stages (Class B stages 1 and 2; Class C JavaScript). Both sets are listed here with their labels, since Sekoia does not explain the difference, possibly because samples vary. Verify against the report before relying on any single label [S2].
- Coverage disagrees on the number of unused vulnerabilities in the code. BleepingComputer reports four others in unreachable code or alternate paths [S1], whereas the portions reviewed in Sekoia's report name two, CVE-2024-27808 and CVE-2024-27833, as dead code [S2].
- CVE-2024-27834 was fixed in iOS 16.7.8 according to NVD [S20], yet the Class A delivery filter includes 16.7.10 [S2]. Sekoia suggests the mismatch in delivery and exploit ranges points to reused exploits, and how Class A works against 16.7.10 is unclear.
- BleepingComputer states the Plerdy tracker loaded across thousands of sites [S1], and Help Net Security adds an Australian medical clinic with low confidence it served specific targeting [S4]. Sekoia's mention of the clinic reads as an unrelated entity [S2].
- Related activity shows the wider trend. Microsoft tied the CaptiveCrunch hotel and conference Wi-Fi attacks to a Midnight Blizzard sub-cluster, which also targeted Microsoft 365 tokens and credentials [S17]. The

Hacker News reports the DeadTag criminal operation using expired analytics domains to push Coruna or DarkSword P7, and Zimperium counted 608 domains delivering Coruna-family code as of October 2026 [S3].

- Sekoia cites open-source reporting that Ukraine's president stayed at Raffles London around 14 October 2026, in the context of the hotel lookalike. It is circumstantial and does not show he or his staff were targeted [S2].

CTI-20261104-03 v1.0 · Generated 2026-11-04 10:11 EST from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

Back to the daily briefing.

TLP:CLEAR Unrestricted public release.